Password and Authentication Standard

Document ID	SEC-003
Department	IT and Information Security
Document type	Standard
Owner	Security Engineering Manager
Version	1.0
Status	APPROVED
Effective / last reviewed	2026-01-18
Audience	All employees and contractors
Related documents	SEC-002, SEC-004, SEC-006

Summary. Technical standard for passwords, multi-factor authentication and sessions at Northstar. Sets the 14-character minimum, no routine rotation, NorthVault use, lockout, hardware keys for privileged accounts, service credential rotation, session timeouts, recovery and exception rules.

SYNTHETIC DOCUMENT - Northstar Systems is a fictional company. This document exists for development, testing and demonstration only and is not real legal, employment, security or compliance advice.

1. Purpose and Scope

This standard sets the technical requirements for passwords, passphrases, multi-factor authentication (MFA), sessions and credential handling at Northstar Systems. It implements the identity and access principles of SEC-001 (Information Security Policy) and complements SEC-002 (Access Management Policy), which governs who may hold access. It applies to every employee, contractor and third party who authenticates to a Northstar system, and to every system, application and service account that stores or verifies credentials, including those built by Engineering for the Northstar Nexus Platform.

The standard is owned by the Security Engineering Manager and is reviewed every 12 months. It takes effect on 18 January 2026 and replaces the earlier password guidance that required periodic rotation. Where a regulation or customer contract requires something stricter, the stricter requirement applies; legal and regulatory references in this document are illustrative and must be verified by Legal before external use.

2. Definitions

- **Password**: a secret string known by the user and checked by a system. A passphrase of several words is a password for this standard.
- **MFA**: authentication that combines at least two factors, such as something you know and something you have.
- **NorthID**: the single sign-on platform and identity provider for corporate systems, which enforces MFA.
- **NorthVault**: the approved password and secrets manager for individuals, teams and services.
- **Hardware security key**: a physical FIDO2 device that proves possession cryptographically and resists phishing.

- **Privileged account**: an account with administrator rights, production access, or the ability to change security controls.
- **Service account**: a non-human account used by an application, pipeline or integration.
- **Break-glass account**: an emergency privileged account used when normal sign-in is unavailable.
- **Credential stuffing**: an attack that replays passwords leaked from other sites against corporate systems.
- **Compromise**: confirmed or reasonably suspected exposure of a credential to someone not authorised to use it.

3. Roles and Responsibilities

Role	Responsibility
Security Engineering Manager	Owns this standard, configures password rules and MFA policies in NorthID
Head of IT Operations	Operates NorthID and NorthVault, enrols users, runs the IT Service Desk recovery process
System owners	Ensure their applications integrate with NorthID and do not store passwords themselves
Engineering teams	Keep secrets out of source code and use NorthVault or a KMS-backed secret store
IT Service Desk (extension 4000)	Verifies identity and handles lockouts, MFA resets and key replacement
Security Desk (extension 5555)	Receives reports of suspected compromise and coordinates containment
All personnel	Protect their credentials, enrol MFA, and report loss or suspicion at once

4. Password Requirements

4.1 Length and composition

1 Every password for a corporate account must be at least 14 characters long.
2 A passphrase of four or more unrelated words is encouraged because it is long and memorable.
3 Complexity rules (forced symbols or upper-case letters) are not required. Length and uniqueness matter more than character mix.
4 Privileged accounts must use a password of at least 20 characters, in addition to a hardware security key.
5 Passwords must not contain the user's name, employee ID (NS- followed by five digits), the company name, or a simple keyboard pattern.
6 NorthID checks each new password against a list of known breached and commonly used passwords and rejects any match.

4.2 No forced periodic rotation

Northstar does not require periodic password changes. Research shows that forced rotation leads users to choose weaker, predictable passwords. A password must be changed only when compromise is suspected or confirmed, when the person who set a shared team secret leaves, or when a system owner directs it after an incident. When a password is changed, the new one must not be a small variation of the old one.

4.3 Uniqueness and reuse

Reuse of the same password across systems is forbidden. A corporate password must never be used on a personal site, and personal passwords must never be used on corporate systems. NorthVault generates unique passwords so people need to remember only a few secrets: the NorthVault master credential and the primary NorthID password.

4.4 Storage and sharing

- All passwords must be stored in NorthVault. Writing passwords on paper, in spreadsheets, in chat, in email or in browser-saved password stores is prohibited.
- Passwords must never be shared with colleagues, managers or IT staff. A person who needs access to a system must request it under SEC-002.
- Team secrets that several people legitimately need (for example a vendor portal that supports only one login) must be held in a NorthVault shared folder with a named owner, and the use of that folder is logged. Shared accounts remain prohibited where the tool supports individual accounts.
- Passwords must never appear in source code, configuration committed to version control, tickets, wiki pages or logs.

5. Multi-Factor Authentication

5.1 Scope

MFA is mandatory for all employees on all corporate systems, authenticated through NorthID. This covers email, NorthPeople, NorthPay, NorthBuy, NorthDesk, NorthShip, NorthWatch, NorthAssist, the NorthTunnel VPN, cloud consoles and source control. No application may be exposed to employees with password-only sign-in.

5.2 Approved factors

Factor	Use	Notes
Hardware security key (FIDO2)	Required for privileged accounts, preferred for everyone	Phishing resistant
NorthID authenticator app with number matching	Standard factor for employees	Push approval alone is not accepted
One-time code from the authenticator app	Fallback when no data connection	Codes expire in 30 seconds
SMS or voice call	Not permitted for employees	Weak against SIM swap attacks

Each user must register at least two factors, so a lost phone does not lock them out. A user must not approve an MFA request they did not trigger. Unexpected prompts are treated as an attack and reported to the Security Desk immediately, because they may indicate that the password has been stolen (MFA fatigue attack).

5.3 Privileged accounts

Privileged accounts need a hardware security key and a password of at least 20 characters. Privileged access to production is also granted just-in-time for a maximum of 8 hours under SEC-002 and is performed only through the NorthGate bastion with session recording. Admin consoles use a session timeout of 1 hour.

5.4 Enrolment

New joiners enrol MFA on day 1 with the IT Service Desk before any other system is used. Hardware keys are issued to privileged account holders and to anyone whose role requires one; the person signs for the key and the asset is tracked under the asset tag process. An employee must keep the key separate from the laptop when travelling.

6. Lockout, Sessions and Timeouts

6.1 Account lockout

An account is locked for 15 minutes after 5 failed sign-in attempts. The counter resets after a successful sign-in. A locked account can be released early only by the IT Service Desk after identity verification, and repeated lockouts from unfamiliar locations are reported to the Security Desk. Lockout must not reveal whether the user name or the password was wrong.

6.2 Session timeouts

Type of system	Maximum session	Notes
Standard applications	12 hours	Re-authenticate through NorthID
Admin consoles and privileged tools	1 hour	Re-authentication with the hardware key
Device screen lock	5 minutes of inactivity	Enforced through NorthGuard (see SEC-004)

Sessions must be ended when the user signs out, when a role changes, and when an account is disabled. Applications that keep their own session store must honour revocation from NorthID within 15 minutes.

7. Service Accounts, Secrets and API Credentials

1 Service account credentials must be rotated every 90 days. Rotation should be automated through NorthVault or the KMS-backed secret store, and a rotation that fails raises a NorthDesk ticket.
2 Each service account must have a named human owner, a documented purpose and the least privileges needed.
3 Credentials must never be embedded in source code. NorthShip pipelines scan every commit for secrets, and a detected secret is revoked immediately, then removed from history.
4 Interactive sign-in by a service account is prohibited.
5 API tokens issued to customers for the Northstar Nexus Platform are customer-managed. Customers are advised to rotate them in Workspace settings when an NX-1001 authentication failure appears or when staff with token access leave.
6 Where OAuth 2.0 client credentials are used for service access, client secrets follow the same 90-day rotation rule.

Example: The NorthShip deployment service account for the billing service was last rotated on 3 February. It must be rotated again on or before 4 May. Automation rotates it on 20 April, and the new secret is written to the KMS-backed secret store; the rollout is verified in NorthWatch.

8. Recovery and Reset Procedures

8.1 Forgotten password

1 The user opens the NorthID self-service reset page and proves identity with a registered MFA factor.
2 The user sets a new password that meets section 4.
3 NorthID logs the event and informs the user's registered email.

8.2 Lost or replaced MFA device

1 The user contacts the IT Service Desk on extension 4000 from a known channel.
2 The Service Desk verifies identity with a video call and the reporting manager's confirmation, never by email alone.
3 The old factor is revoked and a new factor is enrolled. For privileged users, a replacement hardware key is issued, and the lost key is revoked at once.
4 A lost phone or key is also treated as a lost device: the Security Desk must be informed within 1 hour of discovery (see SEC-004).

8.3 Suspected compromise

1 Call the Security Desk at extension 5555 immediately.
2 The Security Desk forces a password change, revokes sessions and tokens, and reviews recent sign-ins in NorthWatch.
3 If the password was reused anywhere else, those passwords are changed too.
4 The user may be asked to take retraining. Reporting promptly is never penalised.

8.4 Break-glass accounts

Break-glass credentials are stored sealed, with the secret split between two custodians. Each use needs a ticket, is alerted in real time, and must be reviewed within 1 business day. After a use, the credential is rotated. Break-glass accounts are never used for routine work.

9. NorthVault Usage Rules

NorthVault is the only approved place for credentials. The following rules apply to its use.

1 The NorthVault master credential must be a passphrase of at least 14 characters (20 for privileged account holders) and must be used nowhere else.
2 Personal vaults are for one person's credentials. Shared folders are for team credentials and must have a named owner who reviews membership every quarter during the access review described in SEC-002.
3 When a person leaves a team, the folder owner removes them from shared folders on the same day, and rotates any secret that person could read if the secret protects Confidential or Restricted systems.
4 Vault entries for production systems must record the system, the owner and the next rotation date, so overdue rotations show up in NorthWatch dashboards.
5 Exporting vault contents to files is blocked. If a migration requires an export, the Head of IT Operations must approve it in NorthDesk and the file must be deleted within 24 hours.
6 NorthVault audit logs are kept for 24 months with other security audit logs and are reviewed weekly by Security Operations.

10. Worked Scenarios

Example 1, MFA prompt you did not request: An analyst in the Mumbai office receives three number-matching prompts at 02:10 IST while asleep. She must deny all of them, and on waking must call the Security Desk. The Security Desk forces a password change, revokes her sessions

and checks NorthWatch for sign-ins from unfamiliar locations. Because a breached password was the likely cause, she is also asked to confirm that she did not reuse it elsewhere.

Example 2, new joiner: A new Software Engineer joins on a Monday. On day 1 the IT Service Desk issues the laptop, she enrols the authenticator app and a second factor in NorthID, creates her NorthVault master passphrase of 16 characters, and sets her NorthID password. Her reporting manager has already submitted the Access Request form, so source control and NorthShip access appear the same day. She completes the security training in NorthLearn within 14 days.

Example 3, lost hardware key: An SRE who holds a privileged account loses her hardware key at the airport. She reports it to the Security Desk within 1 hour and to the IT Service Desk. The key is revoked, any open privileged session ends, and a replacement key is issued after a video-call identity check and manager confirmation. Until then her production access stays suspended, and a request for emergency access must be approved by the Engineering Director on call under SEC-002.

Example 4, secret committed by mistake: A developer commits a cloud access key to a feature branch. The NorthShip secret scan blocks the merge and alerts the Security Desk. The key is revoked within minutes, a new one is issued and stored in the KMS-backed secret store, and the commit is removed from history. The incident is recorded in NorthDesk as a near miss with a short blameless review.

10.1 Quick reference

Item	Requirement
Minimum password length	14 characters
Privileged account password	20 characters plus a hardware security key
Periodic rotation	None; change only on suspected compromise
Failed attempts before lockout	5, locked for 15 minutes
Standard application session	12 hours
Admin console session	1 hour
Service account credential rotation	Every 90 days
Where passwords are kept	NorthVault only

Teams that build applications for employees must also remember that sign-in pages should support paste into the password field, so that NorthVault autofill can work, and that error messages must not reveal whether an account exists.

11. Exceptions

- A system that cannot support MFA through NorthID, or cannot accept a 14-character password, needs a risk acceptance from the CISO delegate with an expiry of at most 90 days, and compensating controls such as access only through NorthTunnel and extra log review.
- Exceptions for SMS factors are not granted for employees. Customers' end users of the product are outside this standard.
- Any exception that would allow shared passwords for privileged accounts, passwords outside NorthVault, or a password under 14 characters is not permitted.
- An expired exception is a policy violation and the control owner must restore compliance.

12. Frequently Asked Questions

- Do I have to change my password every 90 days? No. Rotation is only required after suspected compromise. Service account credentials, however, are rotated every 90 days.
- Can I save a password in my browser? No. Use NorthVault only.
- What if I am travelling without a mobile signal? Use the one-time code from the authenticator app or your hardware key.
- Can I get my password from the IT Service Desk if I forgot it? No. The Service Desk never knows or asks for passwords. Use self-service reset.
- Is a 12-character password with symbols acceptable? No. The minimum is 14 characters regardless of complexity.

13. Related Documents

See SEC-001 for the overall security policy and SEC-002 for access approval. Device lock and encryption rules are in SEC-004. See SEC-006 for further authentication-related procedures.

14. Revision History

Version	Date	Change
0.9	2025-09-12	Draft circulated for review
1.0	2026-01-18	First approved release; replaces earlier guidance requiring periodic password rotation